

Active Reconnaissance & Vulnerability Assessment Report

TARGET: INTERVIEW-QUIZ-BUDDY.LOVABLE.APP

1. Executive Summary

An authorized active reconnaissance and vulnerability assessment was successfully completed against the web application domain interview-quiz-buddy.lovable.app. The audit mapped the external attack surface, evaluated running services, verified cryptographic transport compliance, and inspected exposed security headers.

The target environment uses an enterprise edge protection network layer (**Cloudflare Web Proxy/WAF**), which isolates the underlying origin server and uniformly filters non-web ports. Public accessibility is strictly restricted to standard and alternative web traffic streams on ports 80, 443, 8080, and 8443.

Transport layer security (SSL/TLS) complies with modern industry baselines, exclusively allowing secure TLS 1.2 and TLS 1.3 protocol suites. Automated scanners flagged potential exposures regarding legacy administrative components (/jmx-console/) and omissions in browser enforcement controls, particularly the absence of an HTTP Content Security Policy (CSP). The overall infrastructure risk posture is classified as **Medium**, requiring targeted path verification and security header tuning.

2. Objective & Scope

2.1 Objective

The operational objectives of this assessment were to systematically uncover public endpoints, identify running services and application framework layouts, check the integrity of transit layer encryption, and locate potential misconfigurations or missing defensive headers.

2.2 Scope

The testing boundaries were restricted entirely to the following coordinates:

- **Domain Name:** interview-quiz-buddy.lovable.app
- **Resolved IPv4 Addresses:** 185.41.148.1, 185.41.148.2
- **Resolved IPv6 Addresses:** 2a07:8240::1, 2a07:8240::2

All testing was completed from an external, unauthenticated black-box perspective. Source code access and credentialed systems were out of scope.

3. Tools & Methodology

Standard security utilities were leveraged in an ordered lifecycle covering reconnaissance, network scanning, version enumeration, and vulnerability probing:

Tool	Purpose
DNS Utilities (nslookup/ host)	Domain resolution and analysis of HTTP Service Bindings / ALPN variables.
Nmap (v7.98)	Port verification, service version fingerprinting, and vulnerability signature checking.
Nikto (v2.6.0)	Web server folder enumeration and fallback deployment analysis.
SSLScan (v2.1.5)	Cipher suite strength, cryptographic protocol tracking, and renegotiation auditing.

4. Port & Service Enumeration

Out of 1,000 standard ports scanned, **996 TCP ports are actively filtered** by a perimeter firewall. Four open web proxy interfaces were discovered:

Port/Protocol	State	Service Class	Version Information / Banner
80 / TCP	Open	http	Cloudflare http proxy
443 / TCP	Open	ssl/http	Cloudflare http proxy (Title: Interview Code)
8080 / TCP	Open	http-proxy	Cloudflare http proxy
8443 / TCP	Open	ssl/http	Cloudflare http proxy (Title: Interview Code)

Aggressive operating system fingerprinting returned low-confidence guesses due to the lack of closed ports required for exact TCP/IP stack mapping. The target kernel remains masked by the edge architecture.

```

kali@kali: ~
Session Actions Edit View Help
kali@kali:~$ nmap -sV interview-quiz-buddy.lovable.app
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-14 08:45 -0400
Nmap scan report for interview-quiz-buddy.lovable.app (185.41.148.2)
Host is up (0.048s latency).
Other addresses for interview-quiz-buddy.lovable.app (not scanned): 2a07:8240::2 2a07:8240::1 185.41.148.1
rDNS record for 185.41.148.2: lovable-app-wd-2-4.p.l5e.io
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Cloudflare http proxy
443/tcp   open  ssl/http Cloudflare http proxy
8080/tcp  open  http    Cloudflare http proxy
8443/tcp  open  ssl/http Cloudflare http proxy

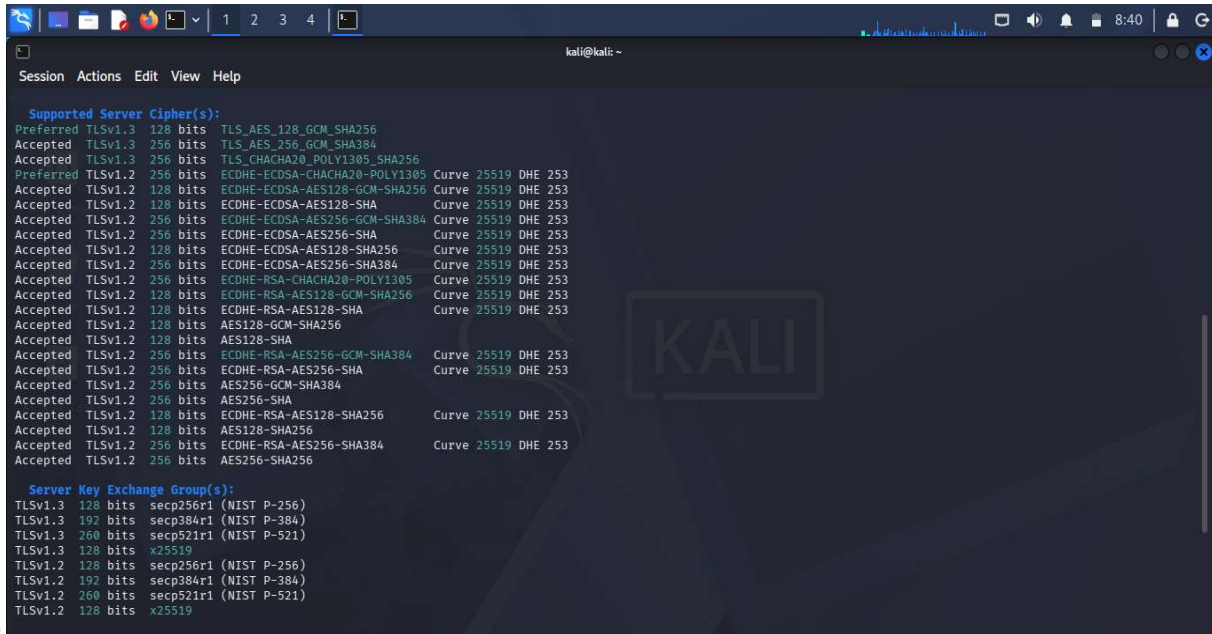
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.81 seconds
kali@kali:~$

```

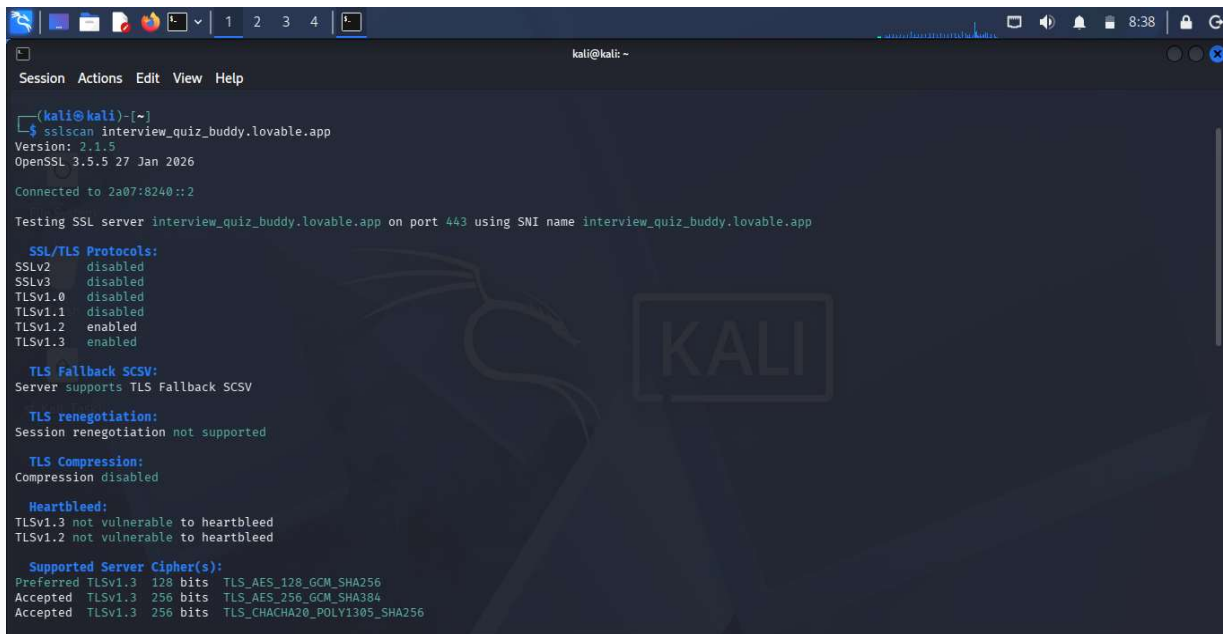
5. SSL/TLS Cryptographic Analysis

An audit over IPv6 (2a07:8240::1) on port 443 confirmed a secure cryptographic posture:

- **Protocols:** Insecure versions (SSLv2, SSLv3, TLS 1.0, TLS 1.1) are explicitly disabled. Secure versions (TLS 1.2, TLS 1.3) are supported.
- **Ciphers:** High-strength AEAD ciphers are preferred, specifically TLS_AES_128_GCM_SHA256 and TLS_AES_256_GCM_SHA384.
- **Vulnerabilities:** Secure renegotiation is properly handled, TLS compression is disabled, and the service is not vulnerable to Heartbleed.



```
kali@kali: ~  
Session Actions Edit View Help  
  
Supported Server Cipher(s):  
Preferred TLSv1.3 128 bits TLS_AES_128_GCM_SHA256  
Accepted TLSv1.3 256 bits TLS_AES_256_GCM_SHA384  
Accepted TLSv1.3 256 bits TLS_CHACHA20_POLY1305_SHA256  
Preferred TLSv1.2 128 bits ECDHE-ECDSA-CHACHA20-POLY1305 Curve 25519 DHE 253  
Accepted TLSv1.2 128 bits ECDHE-ECDSA-AES128-GCM-SHA256 Curve 25519 DHE 253  
Accepted TLSv1.2 128 bits ECDHE-ECDSA-AES128-SHA Curve 25519 DHE 253  
Accepted TLSv1.2 256 bits ECDHE-ECDSA-AES256-GCM-SHA384 Curve 25519 DHE 253  
Accepted TLSv1.2 256 bits ECDHE-ECDSA-AES256-SHA Curve 25519 DHE 253  
Accepted TLSv1.2 128 bits ECDHE-ECDSA-AES128-SHA256 Curve 25519 DHE 253  
Accepted TLSv1.2 256 bits ECDHE-ECDSA-AES256-SHA384 Curve 25519 DHE 253  
Accepted TLSv1.2 256 bits ECDHE-RSA-CHACHA20-POLY1305 Curve 25519 DHE 253  
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-GCM-SHA256 Curve 25519 DHE 253  
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA Curve 25519 DHE 253  
Accepted TLSv1.2 128 bits AES128-GCM-SHA256  
Accepted TLSv1.2 128 bits AES128-SHA  
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-GCM-SHA384 Curve 25519 DHE 253  
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-SHA Curve 25519 DHE 253  
Accepted TLSv1.2 256 bits AES256-GCM-SHA384  
Accepted TLSv1.2 256 bits AES256-SHA  
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA256 Curve 25519 DHE 253  
Accepted TLSv1.2 128 bits AES128-SHA256  
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-SHA384 Curve 25519 DHE 253  
Accepted TLSv1.2 256 bits AES256-SHA256  
  
Server Key Exchange Group(s):  
TLSv1.3 128 bits secp256r1 (NIST P-256)  
TLSv1.3 192 bits secp384r1 (NIST P-384)  
TLSv1.3 260 bits secp521r1 (NIST P-521)  
TLSv1.3 128 bits x25519  
TLSv1.2 128 bits secp256r1 (NIST P-256)  
TLSv1.2 192 bits secp384r1 (NIST P-384)  
TLSv1.2 260 bits secp521r1 (NIST P-521)  
TLSv1.2 128 bits x25519
```



```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ ssllscan interview_quiz_buddy.lovable.app  
Version: 2.1.5  
OpenSSL 3.5.5 27 Jan 2026  
Connected to 2a07:8240::2  
  
Testing SSL server interview_quiz_buddy.lovable.app on port 443 using SNI name interview_quiz_buddy.lovable.app  
  
SSL/TLS Protocols:  
SSLv2 disabled  
SSLv3 disabled  
TLSv1.0 disabled  
TLSv1.1 disabled  
TLSv1.2 enabled  
TLSv1.3 enabled  
  
TLS Fallback SCSV:  
Server supports TLS Fallback SCSV  
  
TLS renegotiation:  
Session renegotiation not supported  
  
TLS Compression:  
Compression disabled  
  
Heartbleed:  
TLSv1.3 not vulnerable to heartbleed  
TLSv1.2 not vulnerable to heartbleed  
  
Supported Server Cipher(s):  
Preferred TLSv1.3 128 bits TLS_AES_128_GCM_SHA256  
Accepted TLSv1.3 256 bits TLS_AES_256_GCM_SHA384  
Accepted TLSv1.3 256 bits TLS_CHACHA20_POLY1305_SHA256
```



6. Web Application & Security Header Analysis

Inspection of transactional HTTP headers revealed that security controls are partially implemented:

- **HSTS:** Active (strict-transport-security: max-age=31536000; includeSubDomains).
- **MIME Sniffing:** Defended (x-content-type-options: nosniff).
- **Referrer Policy:** Configured (referrer-policy: strict-origin-when-cross-origin).
- **Missing Controls:** Both Content-Security-Policy (CSP) and X-Frame-Options headers are missing.

Automated scanning scripts encountered active edge disruptions. Nikto was blocked upon detecting a Cloudflare cf-ray signature, and Nmap vulnerability modules reported unexpected exceptions (ERROR: Script execution failed), highlighting that the edge proxy blocks aggressive scanning tools.

7. Risk Assessment Matrix

Likelihood	Low Impact	Medium Impact	High Impact
High	Un-tokenized Form (/ submit)	Missing HTTP CSP Header	--
Medium	--	Exposed Directory Listings	Potential JBoss JMX Path
Low	--	Missing Frame Controls	--

8. Detailed Vulnerability Analysis

Finding 1: Potential JBoss JMX Console Unauthenticated Access Warning

Severity: **High** CVE: CVE-2010-0738
Port: 443 / 8443 TCP

Description: The Nmap vulnerability engine flagged an unauthenticated response corresponding to the `/jmxconsole/` path, an administration panel for managing Java-based server environments.

Evidence: From `nmap_vuln.txt`: `/jmx-console/`: Authentication was not required

Risk Impact: An unauthenticated management interface could allow an external attacker to deploy a custom Web Application Archive (WAR) file, potentially leading to arbitrary remote code execution on the server. *Note: Given the Cloudflare proxy infrastructure, this may be a false positive match triggered by generic edge status codes, but requires manual confirmation on the origin server.*

Remediation: Confirm the presence of any legacy Java administration panels on the origin server. If required, restrict access by binding the application to the local loopback interface (127.0.0.1) or implementing explicit path-blocking rules in the Cloudflare WAF configuration to drop external requests to `/jmx-console/`.*

Finding 2: Missing HTTP Content Security Policy (CSP) Header

Severity: **Medium** Category: Security Misconfiguration
Port: 80 / 443 TCP

Description: The web platform omits the Content-Security-Policy response header, leaving browser clients without instructions regarding authorized script source domains.

Evidence: Verified via complete absence within header outputs inside `security_headers.txt`.

Risk Impact: The lack of a CSP leaves the application more vulnerable to Cross-Site Scripting (XSS) and client-side data injection vectors. If an XSS vulnerability exists, browser engines will parse and run unauthorized scripts from malicious third-party locations.

Remediation: Deploy a robust Content-Security-Policy header across all application paths. Begin with a strict configuration baseline (e.g., `default-src 'self'; script-src 'self'; style-src 'self';`) and gradually permit trusted third-party endpoints as required.

Finding 3: Exposure of Common Technical Path Superstructures

Severity: **Medium** Category: Information Disclosure
Port: 8080 / 8443 TCP

Description: Automated directory enumeration via the http-enum script revealed a wide range of standard administrative, database, and system backup path signatures responsive on the web proxy interface.

Evidence: From nmap_vuln.txt: Exposes paths including /phpmyadmin/, /manager/, /backup/, and /.svn/.

Risk Impact: Exposing common administrative directories increases the application's attack surface, allowing malicious actors to target management portals or find sensitive source control fragments (e.g., .svn file leaks).

Remediation: Review the web root directory on the origin server and remove all unused sample scripts, default management directories, and repository logs. For valid interfaces, use the Cloudflare edge layer to implement strict IP whitelisting or enforce multi-factor authentication (MFA).

Finding 4: Missing Frame Controls (Potential Clickjacking Exposure)

Severity: Low **Category:** Security Misconfiguration

Port: 80 / 443 TCP

Description: The application fails to declare framing restrictions via the X-Frame-Options header or the frame-ancestors directive within a Content Security Policy.

Evidence: Checked and confirmed absent from the complete log output inside security_headers.txt.

Risk Impact: Malicious actors could embed the application inside an invisible frame on a third-party domain to execute Clickjacking attacks, tricking authenticated users into clicking on invisible functional options.

Remediation: Configure the web server to inject the X-Frame-Options: SAMEORIGIN header on all HTTP responses, or enforce the frame-ancestors 'self' directive within your Content Security Policy.

9. Security Recommendations & Remediation Plan

Priority 1: Immediate Actions (24-72 Hours)

- **Validate JMX Console:** Confirm whether the /jmx-console/ path actively communicates with backend Java applications. If it exists, restrict access immediately by binding it to the local loopback interface (127.0.0.1) or deploying a path-blocking rule in Cloudflare.
- **Enforce Path Access Restrictions:** Configure Cloudflare WAF rules to drop external requests for sensitive paths like /phpMyAdmin*, /manager*, and /admin*.

Priority 2: Short-Term Hardening (1-2 Weeks)

- **Deploy Content Security Policy (CSP):** Apply a valid Content-Security-Policy response header across all web endpoints to defend against client-side script injection risks.
- **Implement Frame Protections:** Apply the X-Frame-Options: SAMEORIGIN header to mitigate crossdomain framing and clickjacking vectors.

10. Conclusion & References

The external perimeter of `interview-quiz-buddy.lovable.app` shows strong resistance to network-level attacks due to its managed Cloudflare edge deployment, which handles TLS configurations securely and filters out non-web ports. However, weaknesses in security hardening—specifically the lack of a CSP, missing frame controls, and exposed administrative paths—leave the application layer vulnerable. Implementing the prioritized remediation plan will address these gaps and establish a strong defense-in-depth posture.